

TRATADO DE GOBERNANZA DE DATOS Y CUMPLIMIENTO REGULATORIO CRUZADO

ENTIDAD: Neobank Digital, S.A.

MÓDULO 1: Política de Privacidad y Tratamiento de Datos

ENTREGABLE 1.1: Marco de Cumplimiento Regulatorio Cruzado (Documento 1 de 3)

VERSIÓN: 4.2.0-PROD

CLASIFICACIÓN: Estrictamente Confidencial / Secreto Corporativo

CAPÍTULO I: DISPOSICIONES FUNDAMENTALES Y ÁMBITO DE APLICACIÓN JURÍDICA

1.1. Naturaleza del Instrumento y Declaración de Principios

El presente Tratado de Gobernanza de Datos y Cumplimiento Regulatorio Cruzado constituye el marco normativo e imperativo de naturaleza técnico-jurídica que rige, de manera restrictiva y vinculante, todas las operaciones de recolección, almacenamiento, procesamiento, disseminación, transferencia, interconexión y destrucción de datos personales ejecutadas por Neobank Digital, S.A. (en adelante, indistintamente, "la Entidad" o "Neobank Digital"). Este instrumento ha sido estructurado con el objeto de consolidar en un único cuerpo doctrinal las exigencias derivadas del ordenamiento jurídico de la República de Guatemala con los estándares de validez extraterritorial y transfronteriza más rigurosos a nivel global.

La Entidad, en su calidad de institución financiera digital constituida para operar canales de tecnología financiera (Fintech) y servicios bancarios automatizados, reconoce que el dato personal es un activo bajo la propiedad exclusiva del titular. En consecuencia, la arquitectura de software, los modelos de persistencia en bases de datos y los flujos transaccionales deben someterse de forma incondicional a los principios de licitud, lealtad, transparencia, limitación de la finalidad, minimización de datos, exactitud, limitación del plazo de conservación, integridad, confidencialidad y responsabilidad proactiva. Este documento opera como la norma suprema interna de gobernanza tecnológica y es de acatamiento obligatorio para directores, ejecutivos, ingenieros de desarrollo, administradores de sistemas, oficiales de cumplimiento y terceros subcontratados.

1.2. Ámbito de Aplicación Espacial y Extraterritorialidad

El ámbito de aplicación de este tratado se extiende de manera tridimensional, abarcando criterios territoriales, funcionales y personales de estricta observancia. En el plano territorial, rige todas las actividades de tratamiento de datos personales efectuadas dentro de las fronteras de la República de Guatemala, así como aquellas operaciones que empleen infraestructura tecnológica local, centros de datos principales, redes de distribución de contenido (CDN) o nodos perimetrales situados en el espacio soberano nacional. En el plano funcional, se aplica a todo servicio financiero, pasarela de pago, billetera electrónica, algoritmo de asignación crediticia, captación de depósitos, emisión de instrumentos de pago y mecanismos de autenticación biométrica provistos a través de las aplicaciones móviles, portales web y entornos de interfaces de programación de aplicaciones (API) propiedad de Neobank Digital.

En el plano del derecho internacional y la extraterritorialidad, este instrumento vincula de forma obligatoria las operaciones de la Entidad con relación a cualquier usuario, cliente o sujeto de datos que se encuentre situado fuera del territorio guatemalteco, específicamente en la Unión Europea o la República Federativa del Brasil, siempre que las actividades de tratamiento estén relacionadas con la oferta de bienes o servicios a dichos interesados, o con el control de su comportamiento en la medida en que este tenga lugar en dichos espacios geopolíticos. La adopción consciente de este modelo de "cumplimiento cruzado" mitiga el riesgo de asimetría regulatoria y blindo la infraestructura transaccional ante reclamaciones de jurisdicciones foráneas dotadas de potestades sancionatorias transfronterizas.

CAPÍTULO II: FUNDAMENTACIÓN CONSTITUCIONAL Y DERECHO DE AUTODETERMINACIÓN INFORMATIVA

2.1. El Régimen de Protección Constitucional en la República de Guatemala

La arquitectura legal de este tratado encuentra su núcleo de validez y justificación inicial en el bloque de constitucionalidad de la República de Guatemala. Específicamente, el artículo 24 de la Constitución Política de la República de Guatemala consagra con carácter absoluto la inviolabilidad de los actos y documentos de las personas, determinando de forma taxativa que la correspondencia, los documentos y los libros de contabilidad son estrictamente

confidenciales y solo pueden ser revisados o exhibidos en virtud de resolución firme dictada por juez competente, con las formalidades legales de rigor. Neobank Digital asimila este precepto constitucional traduciéndolo en una prohibición técnica absoluta de acceso a los registros de datos, logs transaccionales y bases de datos por parte de cualquier autoridad pública o privada que no presente un mandato judicial escrito, debidamente autenticado, numerado y fundamentado en derecho.

Asimismo, el artículo 30 de la Carta Magna establece el principio de publicidad de los actos administrativos, pero introduce una excepción fundamental e imperativa: aquellos asuntos que se refieran a filiación, comercio, tecnología, seguridad o datos provistos por particulares bajo garantía de confidencialidad quedan excluidos de la inspección pública. El tratamiento automatizado de datos financieros y de identidad llevado a cabo por la Entidad califica rigurosamente dentro de esta excepción constitucional. Toda la información almacenada en los sistemas de Neobank Digital goza del estatus de secreto comercial, tecnológico y financiero, obligándose la institución a desplegar las defensas procesales y técnicas necesarias para repeler cualquier intento de intromisión, auditoría informal o requerimiento de información que pretenda obviar las garantías constitucionales del debido proceso.

2.2. Hermenéutica de la Autodeterminación Informativa y el Habeas Data

A pesar de la ausencia de una ley ordinaria específica y unificada de protección de datos personales en el ordenamiento jurídico guatemalteco, la jurisprudencia constitucional de la Corte de Constitucionalidad ha desarrollado, mediante una interpretación progresiva y sistemática de los derechos implícitos consignados en el artículo 44 constitucional, el derecho fundamental a la autodeterminación informativa. Este derecho se define como la facultad inherente a toda persona de controlar el flujo de sus datos personales, conocer qué información se ha recopilado sobre ella, con qué fines se procesa, a qué terceros se transfiere y exigir su rectificación, actualización o supresión cuando estos sean erróneos, inexactos o recopilados sin una base jurídica lícita.

Neobank Digital incorpora esta doctrina judicial elevándola a estándar operativo interno a través del despliegue del recurso de "Habeas Data Automatizado". La Entidad no suple la falta de legislación ordinaria con vacíos de control; al contrario, autosujeta su plataforma técnica a una fiscalización interna equivalente a las leyes de protección de datos más avanzadas del mundo. Se establece que el consentimiento explícito del usuario es la única llave de acceso legítima para el procesamiento de sus datos en fases comerciales, y que dicho consentimiento puede ser revocado en cualquier momento a través de los mismos canales digitales por los cuales fue otorgado, garantizando la inmutabilidad jurídica de la autodeterminación del cliente.

CAPÍTULO III: ALINEACIÓN CON LA LEGISLACIÓN BANCARIA Y FINANCIERA NACIONAL

3.1. Ley de Bancos y Grupos Financieros (Decreto Número 19-2002)

En su condición de entidad tecnológica que se interconecta con el ecosistema financiero y procesa activos canalizados a través de la banca tradicional, Neobank Digital modela sus políticas de privacidad en estricta consonancia con la Ley de Bancos y Grupos Financieros, Decreto Número 19-2002 del Congreso de la República de Guatemala. El artículo 84 de dicho cuerpo legal instituye de forma categórica el régimen de confidencialidad de las operaciones, determinando que los directores, administradores, representantes legales, asesores y empleados de las entidades financieras no pueden revelar información confidencial relacionada con las operaciones de captación o colocación de fondos, ni los datos de identidad de los cuentahabientes, inversionistas o deudores, salvo los casos expresamente autorizados por la ley o por la Superintendencia de Bancos (SIB).

Este tratado traduce el mandato del artículo 84 en un protocolo de segregación de funciones (SoD - Separation of Duties) a nivel de base de datos y sistemas de infraestructura. Los ingenieros de confiabilidad del sitio (SRE) y los administradores de sistemas de Neobank Digital tienen prohibido por diseño el acceso a datos en texto claro de las transacciones financieras de los clientes. Todos los registros que vinculan la identidad del usuario con sus balances saldos, flujos de efectivo y destinos de transferencia son sometidos a procesos de tokenización y enmascaramiento dinámico de datos (DDM). Los datos financieros sensibles se almacenan en tablas con cifrado criptográfico de columna y solo son accesibles mediante servicios validados con certificados digitales específicos y llaves efímeras asociadas a roles con privilegios mínimos (Principle of Least Privilege).

3.2. Gobernanza de Riesgos Tecnológicos y Circulares de la Superintendencia de Bancos

El tratamiento de datos dentro de Neobank Digital se sujeta minuciosamente a las directrices de la Junta Monetaria y a las resoluciones normativas de la Superintendencia de Bancos en materia de administración del riesgo tecnológico. Las políticas de privacidad aquí descritas configuran el soporte normativo para cumplir con las exigencias de continuidad del negocio, integridad de los datos y auditoría de sistemas. La recolección de metadatos de conectividad, direcciones IP,

geolocalización satelital y patrones conductuales de navegación no responde a un interés comercial arbitrario, sino al cumplimiento de la obligación legal de mantener trazas de auditoría inalterables y mecanismos de detección de anomalías transaccionales.

Toda modificación en los esquemas de bases de datos que afecte el almacenamiento de datos de clientes debe pasar por un proceso de Evaluación de Impacto de Privacidad y Seguridad (PIA/SIA), alineado con los requerimientos de la SIB. La retención de logs de acceso a los sistemas perimetrales y centrales se fija en un período mínimo de cinco (5) años, empleando dispositivos de almacenamiento del tipo WORM (Write Once, Read Many) que impiden la alteración retrospectiva de los datos por parte de agentes internos o externos, asegurando la disponibilidad de evidencia digital incontestable ante eventuales inspecciones de la Intendencia de Verificación Especial o de la Intendencia de Coordinación Técnico-Operativa de la SIB.

CAPÍTULO IV: INTEGRACIÓN DE NORMATIVAS DE PREVENCIÓN DE LAVADO DE DINERO Y CUMPLIMIENTO IVE

3.1. Ley Contra el Lavado de Dinero u Otros Activos (Decreto Número 67-2001)

El tratamiento de datos personales en Neobank Digital encuentra un límite operativo y una obligación de coexistencia armónica con la Ley Contra el Lavado de Dinero u Otros Activos, Decreto Número 67-2001 del Congreso de la República de Guatemala, y su respectivo Reglamento (Acuerdo Gubernativo Número 265-2002). En virtud de esta normativa, la Entidad actúa bajo las obligaciones de un sujeto obligado, lo que impone el deber imperativo de recabar, verificar y actualizar datos de identificación precisos de todos sus usuarios mediante procesos estrictos de Conozca a su Cliente (KYC - Know Your Customer). El almacenamiento de estos datos no es opcional ni está supeditado a la voluntad de eliminación del usuario mientras dure la relación contractual y durante los plazos de prescripción legal posteriores.

El artículo 21 de la referida ley obliga a las entidades a mantener registros detallados de la identidad de sus clientes, contratos, transacciones y documentos de soporte. Neobank Digital ejecuta este mandato estructurando un repositorio de datos aislado y altamente protegido denominado "Módulo de Identidad IVE". Las solicitudes de revocación de consentimiento o supresión de datos presentadas por los usuarios (basadas en principios internacionales o en la autodeterminación informativa) serán rechazadas de manera justificada si entran en colisión directa con la obligación legal de conservación de registros dictada por la normativa de prevención de lavado de dinero. En estos escenarios, los datos del usuario no se eliminan del sistema central, sino que se someten a un estado de bloqueo técnico absoluto (Data Port Locking), quedando excluidos de cualquier procesamiento comercial o analítico, y disponibles exclusivamente para el Oficial de Cumplimiento y las autoridades judiciales o de la Intendencia de Verificación Especial (IVE).

3.2. Formulación Digital de los Formularios IVE y Captación Automatizada

La Entidad ha digitalizado e integrado en el flujo de registro de su aplicación móvil los requisitos informativos contemplados en los formularios oficiales de la Intendencia de Verificación Especial (Formularios IVE-BA-01, IVE-BA-02 y sus anexos). El procesamiento de estos datos incluye la captura de imágenes en alta resolución del Documento Personal de Identificación (DPI), el Número de Identificación Tributaria (NIT), datos de origen de fondos, perfiles económicos, declaraciones de condición de Persona Expuesta Políticamente (PEP) y datos del empleador. El tratamiento de esta información se realiza bajo un canal encriptado directo hacia el sistema central de procesamiento de cumplimiento.

Para asegurar el cumplimiento cruzado y evitar la falsificación de identidad, el sistema de Neobank Digital realiza cruces automatizados de datos mediante consultas cifradas por API con el Registro Nacional de las Personas (RENAP) y la Superintendencia de Administración Tributaria (SAT). Este flujo transaccional de verificación cumple con las exigencias de debida diligencia de la IVE, guardando un registro criptográfico del resultado de cada consulta. El usuario, al aceptar los términos de privacidad, otorga un mandato expreso e irrevocable a la Entidad para realizar estas verificaciones de identidad, entendiendo que el uso de sus datos para fines de cumplimiento legal prevalece sobre las políticas generales de confidencialidad comercial.

CAPÍTULO V: ARMONIZACIÓN CON EL ESTÁNDAR GLOBAL GDPR (GENERAL DATA PROTECTION REGULATION)

5.1. Criterios de Aplicabilidad Transfronteriza (Artículos 3.1 y 3.2 de la GDPR)

Neobank Digital, S.A., a pesar de tener su sede principal y operaciones matrices en la República de Guatemala, adopta de forma proactiva y vinculante las disposiciones del Reglamento General de Protección de Datos de la Unión Europea (Reglamento UE 2016/679 - GDPR). Esta decisión estratégica se fundamenta en los criterios de aplicabilidad territorial definidos en el artículo 3 de dicha norma internacional. Conforme al artículo 3.2, la GDPR resulta aplicable al tratamiento

de datos personales de interesados que residan en la Unión Europea por parte de un responsable o encargado no establecido en la Unión, cuando las actividades de tratamiento estén relacionadas con la oferta de bienes o servicios a dichos interesados, o con el control de su comportamiento (por ejemplo, mediante el uso de cookies de seguimiento, análisis de patrones de gasto transfronterizo, perfiles de riesgo crediticio internacional o remesas dirigidas a ciudadanos comunitarios).

En este sentido, la Entidad asume las responsabilidades jurídicas completas derivadas de la figura de "Responsable del Tratamiento" (Data Controller). Cada vez que un ciudadano o residente de la Unión Europea interactúa con las plataformas de Neobank Digital, se activan de forma automática las salvaguardas tecnológicas y procedimentales exigidas por la GDPR. Esto implica que la Entidad cuenta con un registro exhaustivo de actividades de tratamiento (RoPA - Record of Processing Activities), realiza evaluaciones de impacto relativas a la protección de datos (DPIA) para funciones que impliquen alto riesgo, y mantiene un canal institucional permanente con autoridades de control europeas en caso de incidentes transfronterizos.

5.2. Bases Lícitas para el Tratamiento conforme al Artículo 6 de la GDPR

Para dar estricto cumplimiento al principio de licitud, Neobank Digital prohíbe el procesamiento de cualquier dato personal de ciudadanos protegidos por la GDPR si no cuenta con al menos una de las bases jurídicas taxativamente enumeradas en el artículo 6 del reglamento europeo. La Entidad mapea sus flujos de datos bajo las siguientes tres condiciones principales:

Operación / Flujo de Datos	Base Lícita (GDPR Art. 6)	Mecanismo Técnico de Validación
Evaluación crediticia, apertura de cuenta monetaria, emisión de tarjeta de débito/ crédito.	Artículo 6.1(b): Necesario para la ejecución de un contrato en el que el interesado es parte.	Aceptación digital con firma electrónica avanzada y registro de 'timestamp' inmutable en el core bancario.
Envío de campañas de marketing relacional, ofertas de productos asociados de terceros, analítica predictiva de consumo comercial.	Artículo 6.1(a): El interesado dio su consentimiento para uno o varios fines específicos.	Casilla de verificación (Opt-In) explícita, desmarcada por defecto, con almacenamiento del hash del consentimiento.
Monitoreo de transacciones sospechosas, retención de datos de identidad para la IVE, reportes de actividades financieras sospechosas.	Artículo 6.1(c): Necesario para el cumplimiento de una obligación legal aplicable al responsable del tratamiento.	Inyección automática de metadatos de cumplimiento sin opción de 'Opt-Out' por parte del usuario.

5.3. Derechos Avanzados del Interesado: Portabilidad y Limitación del Tratamiento

Más allá de los derechos tradicionales de acceso y rectificación, la adopción de la GDPR obliga a Neobank Digital a implementar arquitecturas de software capaces de responder a los derechos avanzados de Portabilidad de Datos (Artículo 20) y Limitación del Tratamiento (Artículo 18). El derecho a la portabilidad se ejecuta mediante la habilitación, dentro del perfil de usuario en la aplicación móvil, de una función de exportación que genera de forma inmediata un archivo estructurado, de uso común y lectura mecánica en formato JSON (JavaScript Object Notation) con codificación UTF-8, o alternativamente en formato CSV, que contiene todo el historial de transacciones, datos demográficos y perfiles del cliente.

Por su parte, el derecho a la limitación del tratamiento se traduce en una bandera lógica (flag) en la base de datos principal de la Entidad. Cuando un interesado solicita la limitación de sus datos (por ejemplo, mientras se verifica la exactitud de los mismos tras una impugnación), el microservicio de persistencia bloquea cualquier lectura de dichos registros por parte de los módulos comerciales, analíticos o de inteligencia artificial, permitiendo el almacenamiento estático de los datos pero prohibiendo explícitamente su alteración, transferencia o procesamiento secundario, manteniendo los registros legibles únicamente para fines de defensa legal o por motivos de orden público regulados por la legislación bancaria.

CAPÍTULO VI: CUMPLIMIENTO DEL ESTÁNDAR TRANSFRONTERIZO DE LA LGPD (LEI GERAL DE PROTEÇÃO DE DADOS)

6.1. Extensión Operativa conforme a la Ley Brasileña (Ley N° 13.709)

Debido al crecimiento de las redes de pago globales y a las alianzas estratégicas de Neobank Digital con adquirentes y procesadores de pago de América del Sur, la Entidad integra de forma paralela en su matriz regulatoria la Ley General de Protección de Datos Personales de la República Federativa del Brasil (Lei N° 13.709 - LGPD). Al igual que la GDPR, la LGPD posee un carácter expansivo y se aplica a operaciones de tratamiento ejecutadas en el extranjero si el objeto de la actividad de tratamiento es la oferta o el suministro de bienes o servicios, o el tratamiento de datos de personas naturales

ubicadas en el territorio brasileño.

Neobank Digital asume el cumplimiento de los diez principios fundamentales dictados por el artículo 6 de la LGPD, haciendo especial énfasis en los principios de "Finalidad" (propósitos legítimos, específicos y explícitos informados al titular), "Adecuación" (compatibilidad del tratamiento con las finalidades comunicadas) y "Necesidad" (limitación del tratamiento al mínimo indispensable para la consecución de sus objetivos globalizados). La Entidad reestructura sus avisos de privacidad digitales para asegurar que la información sea presentada en un lenguaje claro, accesible y traducido con precisión técnica al idioma portugués para aquellos usuarios captados bajo esta jurisdicción regional.

6.2. La Figura del Encarregado (Data Protection Officer) y Relación con la ANPD

De conformidad con el artículo 41 de la LGPD, Neobank Digital instituye formalmente la figura del *Encarregado pelo Tratamento de Dados Pessoais* (equivalente internacional al Data Protection Officer o DPO). La identidad y los datos de contacto de este funcionario de alta jerarquía se publican de forma permanente e ininterrumpida en la interfaz principal de soporte de la Entidad. El Encarregado tiene asignadas, por mandato de este tratado, las funciones exclusivas de recibir reclamaciones y comunicaciones de los titulares de datos, prestar aclaraciones, recibir directrices de la *Autoridade Nacional de Proteção de Dados* (ANPD) de Brasil y de la Superintendencia de Bancos de Guatemala, y orientar a los empleados y contratistas de la Entidad respecto de las prácticas de protección de datos.

El Encarregado liderará los comités de respuesta ante incidentes y será el único interlocutor autorizado para notificar a la ANPD y a las autoridades guatemaltecas sobre cualquier evento de vulneración de seguridad que pueda acarrear un riesgo o daño relevante para los derechos de los titulares. Esta notificación, siguiendo el estándar unificado de la Entidad, se ejecutará en un plazo máximo de setenta y dos (72) horas tras la confirmación técnica del incidente, adjuntando un informe detallado con la descripción de la naturaleza de los datos afectados, las medidas de mitigación implementadas y el plan de remediación técnica a nivel de infraestructura.

CAPÍTULO VII: TAXONOMÍA Y CLASIFICACIÓN FORENSE DE DATOS PERSONALES

7.1. Modelo General de Clasificación de Datos

Para evitar la dispersión de controles de seguridad y asegurar un tratamiento homogéneo, Neobank Digital establece una taxonomía forense obligatoria que clasifica todos los datos recolectados en cuatro categorías críticas. Ningún flujo de datos puede existir en los sistemas de la Entidad sin estar explícitamente taggeado con una de estas clasificaciones en los metadatos del esquema de base de datos:

A. Datos Identificables Directos (DID): Información de registro primario que permite establecer la identidad inequívoca del usuario sin necesidad de datos cruzados. Incluye de forma taxativa: Nombre Completo, Código Único de Identificación (CUI) del DPI, Número de Identificación Tributaria (NIT), número de pasaporte, dirección física de residencia y correo electrónico.

B. Datos Biométricos Sensibles (DBS): Datos relativos a las características físicas, fisiológicas o conductuales de una persona natural, obtenidos a través de un tratamiento técnico específico que permite la identificación única. En Neobank Digital, esta categoría comprende exclusivamente los mapas de vectores tridimensionales de geometría facial y las minucias de huellas dactilares utilizadas para la validación de transacciones en dispositivos móviles.

C. Metadatos de Infraestructura y Telemetría (MIT): Información técnica generada automáticamente por la interacción del dispositivo del usuario con los servidores perimetrales de la Entidad. Incluye: Identificador Único Universal de Dispositivo (UUID), Identidad Internacional de Equipo Móvil (IMEI), dirección MAC, direcciones IP (IPv4 e IPv6), registros de logs de llamadas a la API, sistema operativo, versiones del kernel de seguridad y datos precisos de geolocalización por triangulación GPS/Antenas de telefonía.

D. Datos Financieros y Operativos (DFO): Registros numéricos y lógicos asociados a la actividad económica del usuario en la plataforma. Abarca: Números de cuenta clabe enmascarados, numeración PAN de tarjetas de crédito/débito tokenizadas, historial detallado de transacciones (montos, fechas, horas, nombres de comercios receptores, códigos de respuesta ISO 8583), puntajes de riesgo crediticio (Credit Scoring) calculados por algoritmos internos y estados de cuenta consolidados.

CAPÍTULO VIII: EL CONSENTIMIENTO INFORMADO: MECANISMOS DE CAPTURA Y TRAZABILIDAD CRIPTOGRÁFICA

8.1. Perfeccionamiento del Consentimiento mediante Flujos No Ambiguos

Neobank Digital erradica por completo de su arquitectura el uso de consentimientos implícitos, tácticos o presuntos. El

consentimiento para el tratamiento de datos personales debe ser otorgado mediante un acto afirmativo claro, libre, específico, informado e inequívoco. En la práctica digital de la Entidad, esto se traduce en que durante el flujo de registro o la contratación de un nuevo producto financiero, el usuario se enfrenta a interfaces dedicadas donde debe interactuar físicamente activando casillas de selección independientes para cada finalidad del tratamiento.

Las casillas de selección para finalidades comerciales o de compartición con terceros se presentan estrictamente desmarcadas por defecto (Opt-In Puro). Se prohíbe el uso de frases pre-redactadas que asuman la aceptación por el simple hecho de navegar en la plataforma. La interfaz proporciona un enlace directo, de un solo clic, al texto completo de la política de privacidad aplicable a esa operación específica. El sistema está diseñado para bloquear el avance del flujo si el usuario no realiza la acción afirmativa respecto a los consentimientos obligatorios relacionados con la ejecución del contrato y las normativas contra el lavado de dinero de la IVE.

8.2. Trazabilidad Criptográfica del Consentimiento (Ledger Immutable)

Cada vez que un usuario otorga o revoca un consentimiento dentro del ecosistema de Neobank Digital, la acción no se limita a actualizar un estado binario (0 o 1) en una base de datos relacional común. Para cumplir con el principio de responsabilidad proactiva (Accountability), la Entidad genera una traza de auditoría criptográfica inmutable que se almacena en un libro de registro estructurado y firmado digitalmente (Audit Ledger System).

El registro del consentimiento captura de forma obligatoria los siguientes puntos de datos:

- El identificador único anonimizado del usuario (UUID de cuenta).
- La versión exacta de la Política de Privacidad aceptada por el titular.
- La dirección IP de origen desde donde se emitió la aceptación y el ID de dispositivo verificado.
- Una marca de tiempo Unix de alta precisión (Timestamp UTC) provista por un servidor de tiempo NTP estrato 1.
- Un hash criptográfico SHA-256 compuesto por la concatenación de los datos anteriores, firmado con la llave privada del microservicio de identidad de la Entidad.

Este nivel de trazabilidad permite a Neobank Digital demostrar fehacientemente ante cualquier tribunal de justicia de Guatemala o autoridad reguladora internacional (como la ANPD o agencias europeas) la fecha, hora y condiciones exactas bajo las cuales un cliente autorizó el procesamiento de sus datos personales, imposibilitando el repudio interno o externo de las operaciones de gobernanza.

CAPÍTULO IX: RÉGIMEN DE PENALIZACIONES, RESPONSABILIDAD CIVIL Y AUDITORÍA EXTERNA

9.1. Responsabilidad Patrimonial y Sanciones Contractuales Internas

El incumplimiento de las directrices de gobernanza de datos y principios de confidencialidad establecidos en este tratado acarreará consecuencias legales inmediatas para los infractores. En el ámbito laboral e interno, cualquier empleado, desarrollador o administrador de Neobank Digital que eluda los controles criptográficos, extraiga datos sin autorización o configure flujos de software que violen los principios de minimización o finalidad, será sujeto a un proceso de despido justificado por causa legal inmediata, sin responsabilidad para la Entidad, de conformidad con el Código de Trabajo de Guatemala, sin perjuicio de las acciones penales correspondientes bajo la Ley Contra la Delincuencia Informática.

En el plano corporativo, Neobank Digital establece cláusulas de responsabilidad civil con indemnizaciones punitivas automáticas en todos los contratos suscritos con proveedores tecnológicos, empresas de almacenamiento en la nube, pasarelas de pago y asesores externos. Todo tercero que actúe en calidad de "Encargado del Tratamiento" (Data Processor) para la Entidad debe aceptar auditorías técnicas sin previo aviso ejecutadas por el equipo de seguridad de Neobank Digital. En caso de demostrarse una brecha de seguridad provocada por negligencia o dolo del proveedor que resulte en la filtración de datos de clientes, el proveedor responderá de forma solidaria e ilimitada por los daños patrimoniales, costas procesales y multas internacionales impuestas a la Entidad por organismos reguladores transfronterizos.

9.2. Régimen de Auditoría Obligatoria Anual e Independiente

Con el objeto de validar de manera continua la efectividad y el estricto cumplimiento del Marco de Cumplimiento Regulatorio Cruzado, la Junta Directiva de Neobank Digital tiene la obligación indelegable de contratar anualmente una auditoría externa e independiente. Esta auditoría deberá ser ejecutada por una firma internacional de reconocido prestigio especializada en seguridad de la información y derecho digital (calificación Big Four o equivalente con certificaciones de sus miembros del tipo CISA, CISM y CDPSE).

El alcance de la auditoría incluirá la revisión forense de los esquemas de bases de datos, pruebas de penetración en los

microservicios de identidad, verificación de la inmutabilidad del ledger de consentimientos, revisión de los tiempos de respuesta ante solicitudes de derechos ARCO y control de concordancia con las leyes bancarias de la SIB y la IVE de Guatemala, así como con la GDPR y la LGPD. El dictamen final emitido por la firma auditora, junto con el mapa de riesgos y el plan de remediación técnica obligatoria, se elevará de forma directa a la Junta Directiva, al Oficial de Cumplimiento y se mantendrá a disposición de los inspectores de la Superintendencia de Bancos para demostrar el compromiso inquebrantable de la Entidad con la transparencia y la gobernanza de datos del más alto nivel transaccional.
